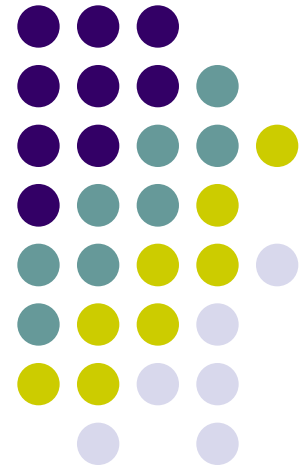
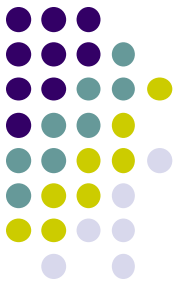


Seguridad Industrial

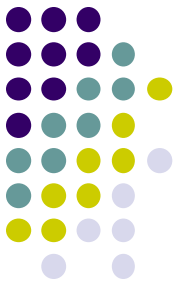
Unidad 5

Seguridad de Redes Sistemas de Seguridad



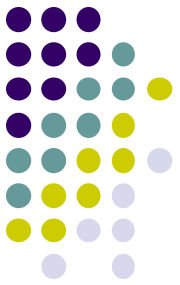


Control de acceso a la red



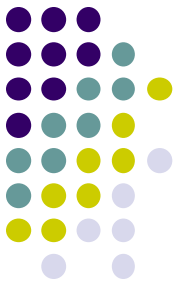
Firewall – Definición

- Sistema que implementa una política de control de acceso entre dos o más redes
- Mejora la seguridad de la red y reduce los riesgos de accesos no autorizados dentro de los sistemas a través de:
 - Concentración de la administración de seguridad
 - Filtrado de servicios / protocolos no deseados
 - Ocultación de información
 - Control de accesos detallado (accounting)



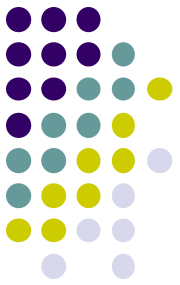
Listas de Control de acceso

- Una **ACL** (Access Control List) es un grupo de sentencias que definen cómo los paquetes entran y salen de las distintas interfaces del firewall
- Las reglas de acceso se recorren de arriba hacia abajo.
La salida de la lista se produce al encontrar la primer regla coincidente



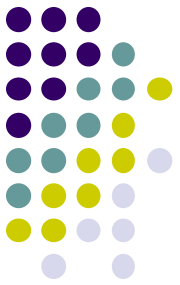
Políticas de ACLs

- Criterio por defecto: Existen dos criterios
 - Por defecto permisivo (**allow all**): Se permite todo y se restringe específicamente lo que se desea proteger.
 - Por defecto restrictivo (**deny all**): Se restringe todo y luego se habilita específicamente lo que se desea permitir.
- Reglas de Acceso (ACL)
 - Una vez establecido el criterio por defecto se crean las reglas de acceso necesarias para permitir el tráfico deseado y restringir el resto.

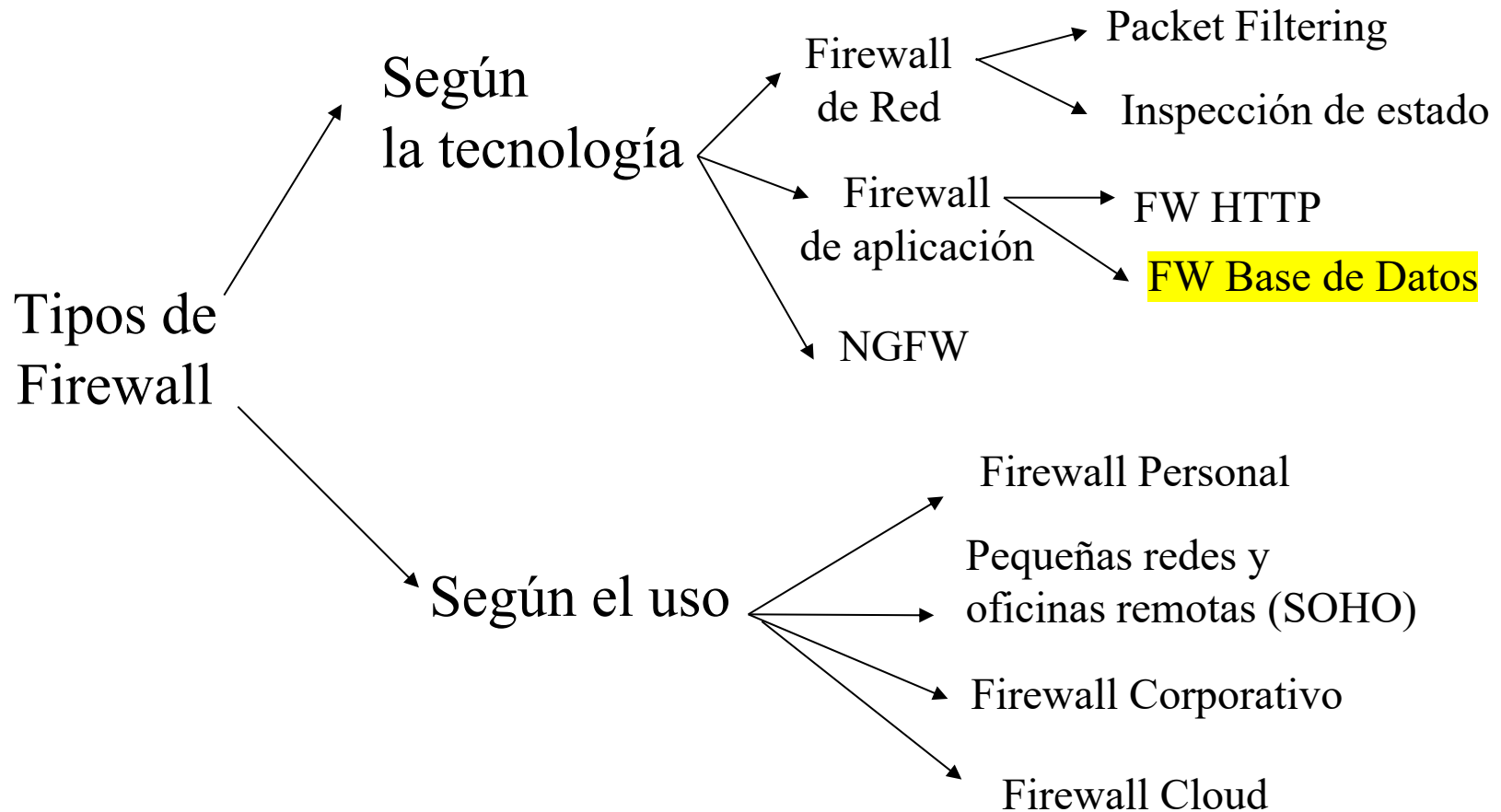


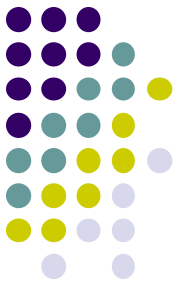
Ejemplo de ACL

- Criterio por defecto restrictivo
- Servidor web de internet: www.myorg.com.ar
- Servidor ftp público : ftp.myorg.com.ar
- Servidor de mail: smtp.myorg.com.ar
- ACLs
 - permitir 80/tcp any www.myorg.com.ar
 - permitir 21/tcp any ftp.myorg.com.ar
 - permitir 22/tcp 189.9.29.223 ftp.myorg.com.ar
 - permitir 25/tcp any smtp.myorg.com.ar
 - denegar any/tcp any any



Clasificación de Firewalls





Firewalls Personales

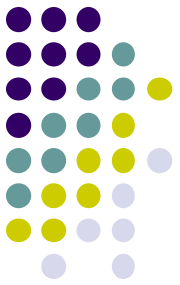
- Protegen un dispositivo controlando el acceso IP al mismo e inspeccionando las aplicaciones más comunes.
- Permiten filtro de entrada y salida
- Dependen del sistema operativo
- De bajo costo e incluso gratuitos.

*El firewall personal que trae Windows para equipos personales es: **Microsoft Defender Firewall** (antes llamado Firewall de Windows).*

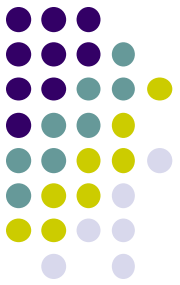
Está integrado en el sistema operativo desde Windows XP y sigue presente en Windows 10 y Windows 11.

Se gestiona desde la aplicación Seguridad de Windows.

Firewalls para pequeñas redes y oficinas (SOHO)

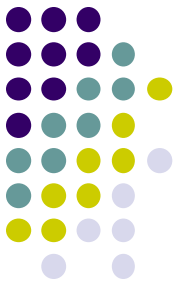


- Protegen a varios usuarios en PYMES y oficinas pequeñas
- Suelen ser pequeños equipos instalados antes del router o incluso integrados al mismo
- Muy utilizado para conexiones compartidas de banda ancha



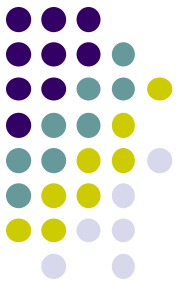
Firewalls corporativos

- Se utiliza como punto de conexión único entre una organización e Internet.
- Permite administrar en forma centralizada las políticas de control de acceso a la red interna.
- Pueden tener varios segmentos de red (DMZ) conectados
- Se implementan soluciones tolerantes a fallas



Firewall de Red – Packet Filtering

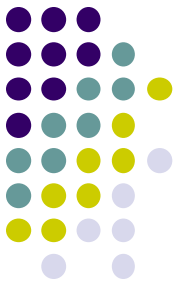
- Actúan dentro del *nivel IP* según el modelo *TCP/IP*
- Suele ser implementado utilizando *routers*
- Cada paquete puede ser analizado en función de:
 - IP origen / destino
 - Puerto origen / destino
 - Protocolo usado: TCP / UDP / ICMP



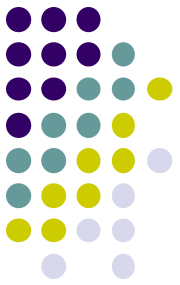
Firewalls Cloud

- Disponibilizan las soluciones tradicionales de Firewalls en entornos de computación de nube
- Pueden ser provistos por el CSP (Cloud Service Provider) o por fabricantes de tecnologías de Firewall
- Aprovechan las ventajas de la computación en nube y se integran con las redes virtuales desplegadas.

Firewall de red – Inspección de estado

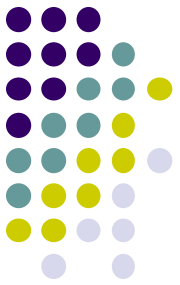


- Actúa dentro de los *niveles de IP, transporte y aplicación* según el modelo *TCP/IP*
- Comprueba (y no procesa, como en un Proxy server) los paquetes a distintos niveles, verificando la validez de estos basándose en un seguimiento del estado de la conexión en cada momento.
- permite conexiones directas entre distintas redes, dando un servicio transparente a ambos lados.



Firewall de aplicación

- Trabaja dentro de los *niveles de aplicación (application gateway)* según el modelo *TCP/IP*.
- Procesa, valida y regenera cada paquete recibido, impidiendo la conexión directa entre 2 redes diferentes.
- Para cada servicio (*telnet, ftp, http...*) se utiliza un proxy específico, pudiendo así prohibir el uso de determinadas órdenes de un servicio.
- Los más utilizados son los firewalls http (también conocidos como WAF, o Web Application Firewalls) y los firewalls de Base de Datos

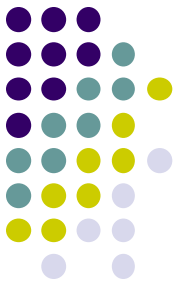


Firewalls http (WAF)

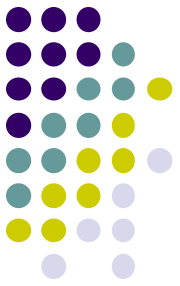
- El aumento de la concientización de seguridad ha hecho que muchas organizaciones implementen controles de seguridad de red y sistemas operativos en forma cada vez más eficientes.
- Como contrapartida los atacantes han migrado los ataques hacia las aplicaciones, que en su mayoría son basadas en web.
- Es por ello que en los últimos tiempos han tenido un fuerte auge los llamados Firewalls HTTP, como elemento esencial para proteger las aplicaciones de una organización, como complemento de los firewalls tradicionales.

Firewalls http (WAF)

Web Application Firewall



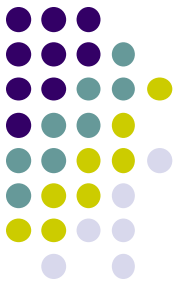
Los firewalls http son firewalls de aplicación que trabajan a nivel de aplicación (capa 7), analizando el tráfico del protocolo http, para detectar y prevenir posibles ataques a las vulnerabilidades específicas de este protocolo.



Firewall http

Métodos de filtrado :

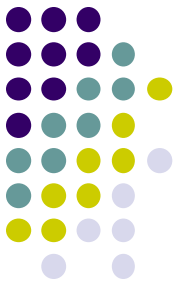
- Filtrado por origen / destino.
- Filtrado por URL.
- Filtrado por el método http utilizado.
- Filtrado por tipo de archivo o contenido referenciado.



Firewall http (WAF)

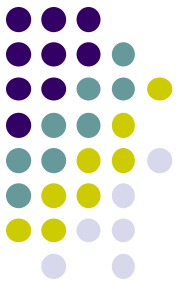
Políticas de acceso y filtrado

- Filtrado por patrones conocidos de vulnerabilidades http (firmas)
- Definición de URLs o tráfico válido
- Validez de las conexiones del protocolo http.



Firewall de Base de Datos

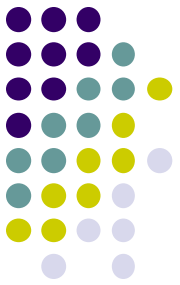
- El Firewall de Base de Datos es una tecnología específica para la detección de ataques a nivel de la base de datos, que permite monitorear y en algunos casos bloquear actividad maliciosa, como así también generar registros que demuestran cumplimiento de políticas y permiten actividad forense detallada.
- La diferencia que tiene con otros Firewalls (como aplicación, y red), es que realiza una evaluación a nivel comandos SQL enviados a los servidores, y establece alarmas y filtros basándose en una lista de conexiones y sentencias SQL sospechosas o fuera de patrón.



Firewall – Arquitectura de conexión

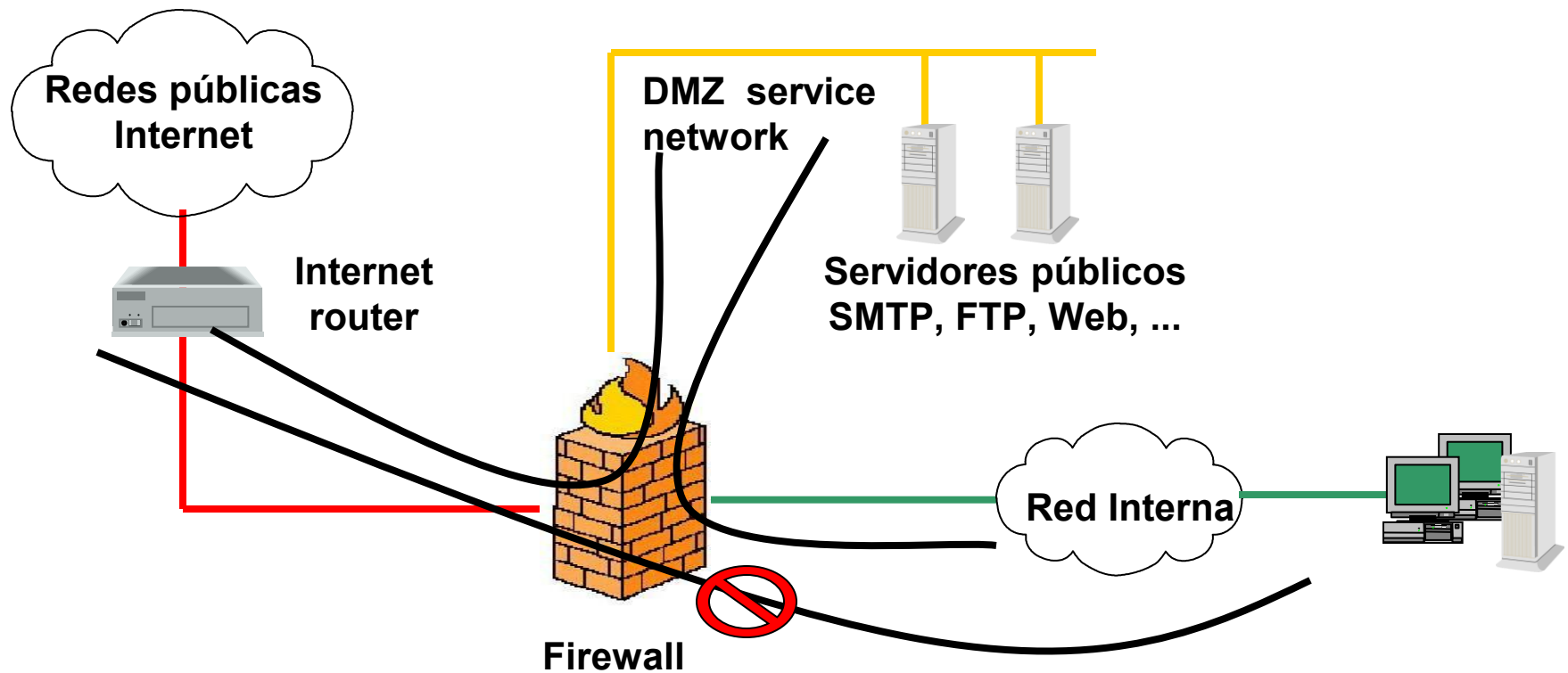
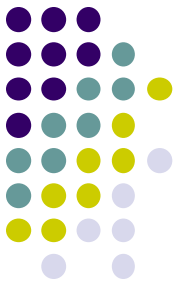
- Interfaces externas
 - Redes públicas y semi-públicas
 - Internet
 - Enlaces privados con otras organizaciones
- Interface interna
 - LAN, Intranet
- DMZ
 - Redes intermedias donde se instalan los servidores que deben conectarse a ambas redes

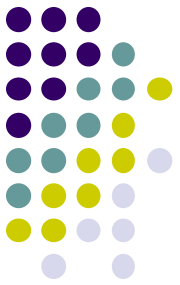
DMZ



- Subred entre red pública y privada (Internet-intranet)
- Se instalan servidores de acceso público (www, mail, ftp, etc.)
- Los accesos a la intranet deben pasar por la DMZ antes de ingresar
- Los servidores instalados en la DMZ deben tener mayores controles de seguridad.

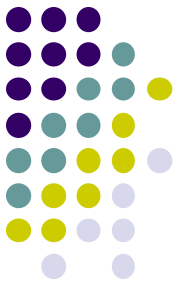
DMZ – Funcionamiento básico





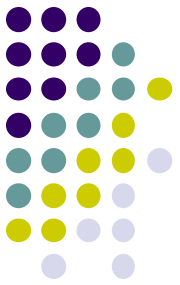
Firewalls de nueva generación (NGFW)

- Los Firewalls de nueva generación (NGFW -Next Generation Firewalls) aplican políticas de control de acceso y seguridad en base a elementos relevantes para la organización como las aplicaciones, el contenido y los usuarios y no en aspectos técnicos de la conexión como son las direcciones de red, puertos, tipo de protocolos y clase de paquetes.
- La siguiente tabla muestra la diferencia entre los Firewalls Tradicionales y los NGFW



Firewalls de nueva generación (NGFW)

Firewall tradicional vs NGFW			
Necesidad de control	Firewall tradicional	Problema / Limitación	NGFW
Quién accede?	Dirección IP	Un usuario puede acceder desde varias direcciones de IP (Wifi – Red Móvil – Red Cableada)	Usuario
Dónde accede?	Protocolo / Puerto	La mayoría de las aplicaciones utilizan puerto http/https. Las aplicaciones pueden enmascararse para utilizar estos puertos aunque naturalmente no los utilicen	Aplicación
Cómo accede ?	Paquete	Sólo puedo filtrar acciones no permitidas de un protocolo (por ej evitar un SYN Flood) pero no puedo prevenir a nivel aplicación (por ej. acceso a un sitio web de contenido malicioso)	Contenido

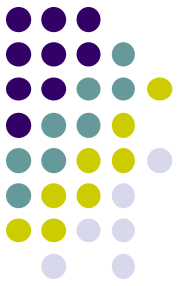


Firewalls de nueva generación (NGFW)

Para lograr esto integran en un mismo dispositivo diferentes funcionalidades como son:

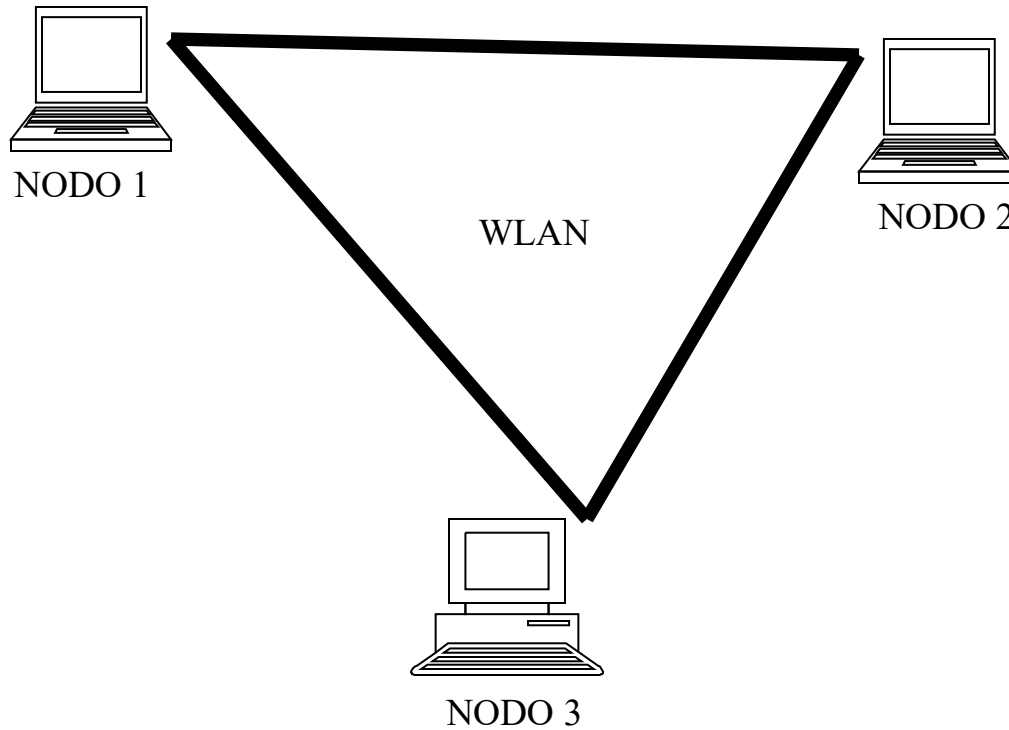
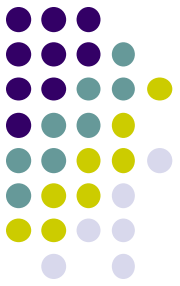
- Identificación y control de aplicaciones
- Autenticación de usuarios
- Mecanismos prevención de intrusos
- Filtrado de contenido
- Prevención de fuga de datos
- Terminación de túneles VPN
- Gestión de tráfico

Seguridad en Redes Inalámbricas

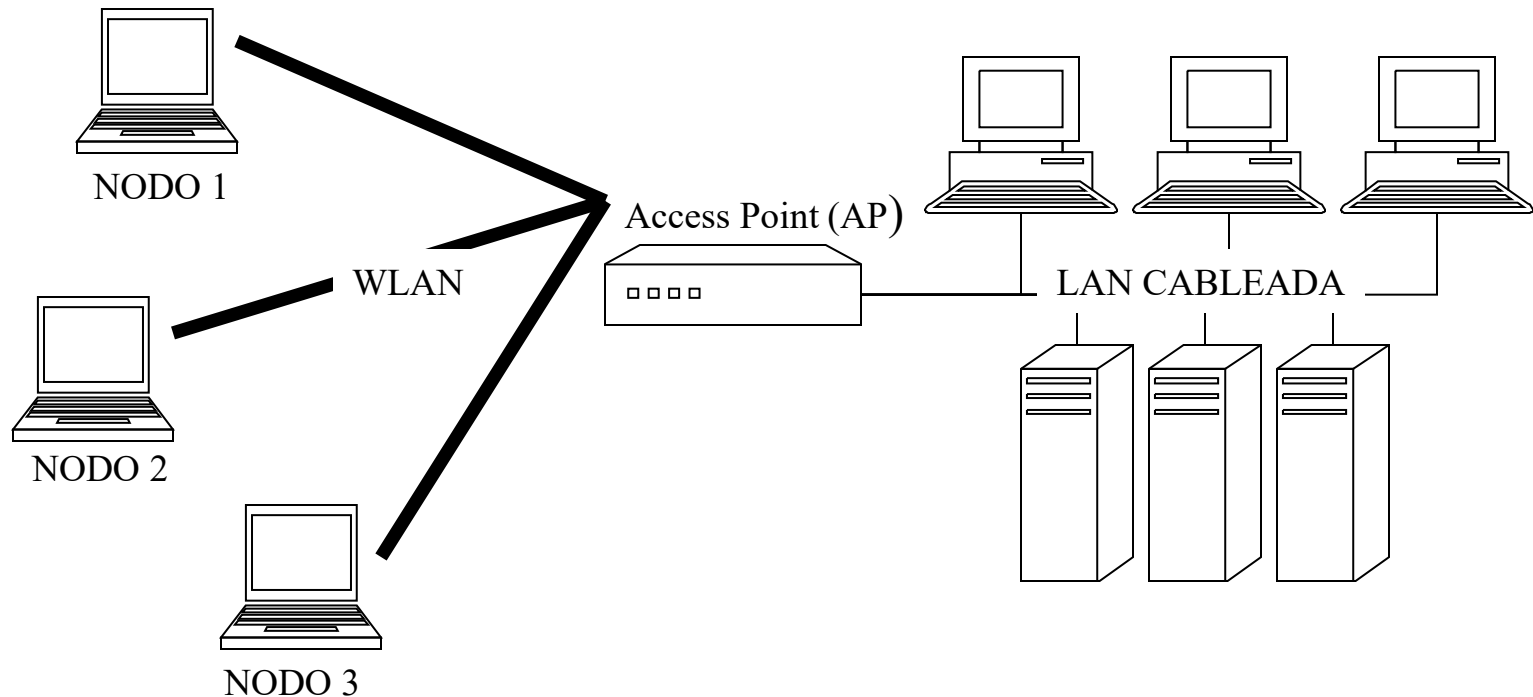
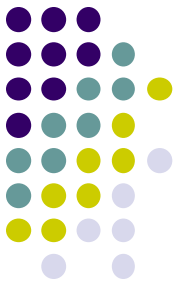


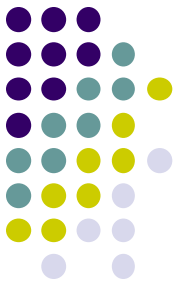
- Definición de Redes Inalámbricas (Wireless LAN o WLAN)
 - Conjunto de computadores que se interconectan entre sí por enlaces de radio (Wireless) formando una LAN

WLAN – Funcionamiento Ad-hoc



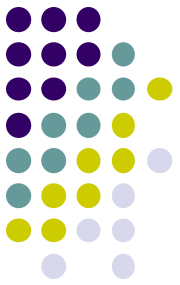
WLAN – Funcionamiento Infraestructura





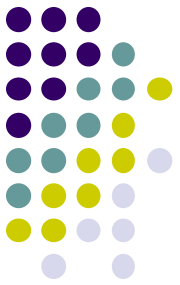
WLAN - Seguridad

- Riesgos :
 - No hay necesidad de acceso físico
 - No hay evidencia física del ataque
 - Ataques remotos desde 100 metros de distancia o hasta 1km con buenas antenas



Familia 802.11x

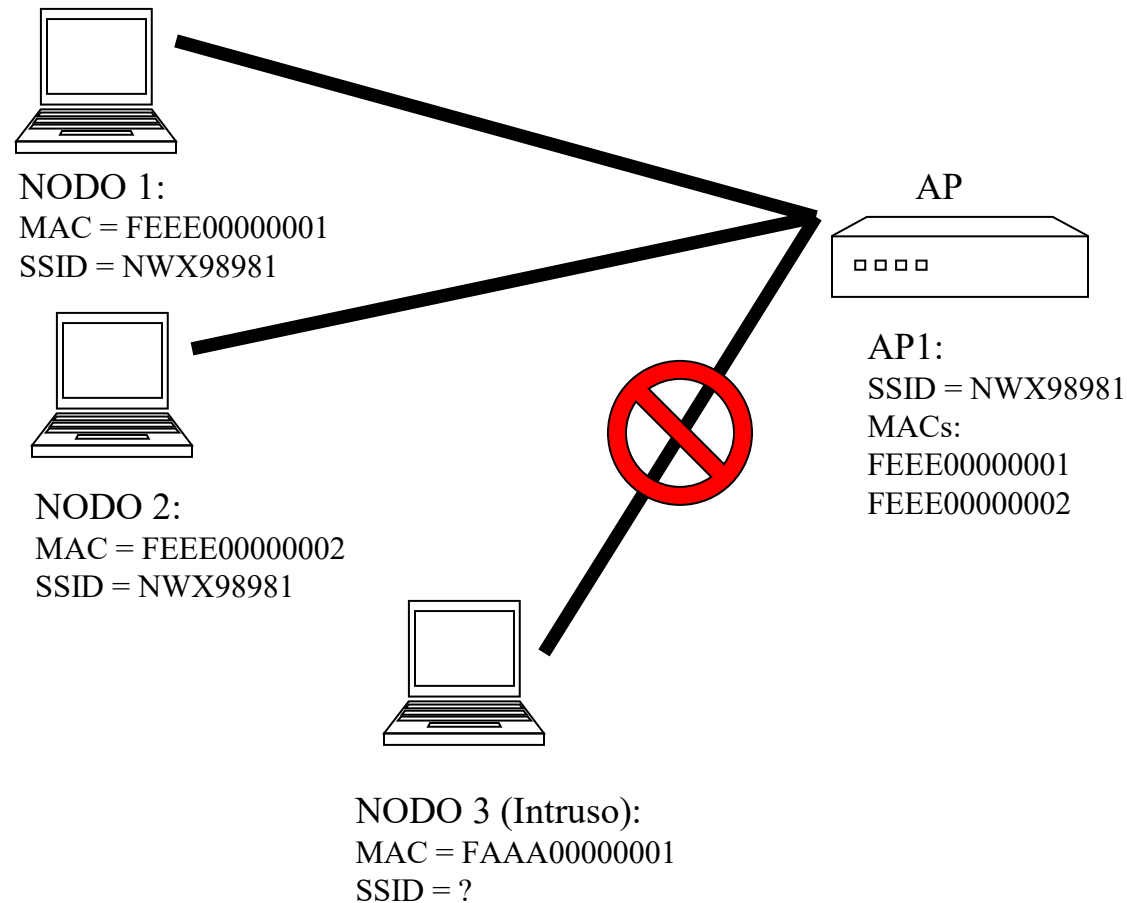
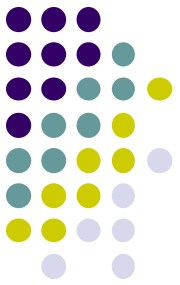
- 802.11 - Estándar original 1-2Mbps en la banda de 2.4 Ghz
- 802.11a - 54Mbps, en la banda de 5GHz
- 802.11b - 11Mbps, en 2.4 GHz , ampliamente difundido
- 802.11g - Mayores velocidades (hasta 54 Mbps a 2.4 GHz)
- 802.11e – QoS (Calidad de Servicio)
- 802.11i - Seguridad y Autenticación
- 802.11n – 54 a 600Mbps (300Mbps teóricos en la actualidad)

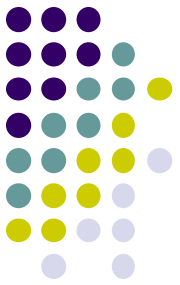


WLAN - Seguridad

- Controles básicos de Seguridad en IEEE 802.11b
 - SSID
 - Filtrado por Mac
 - Encriptación (WEP)

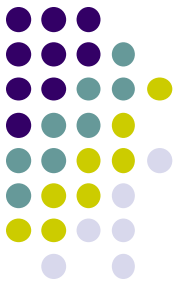
WLAN – Seguridad IEEE 802.11b





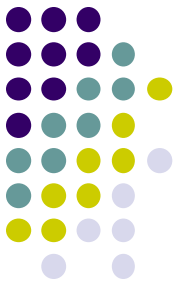
WLAN - Seguridad

- Vulnerabilidades de Seguridad en IEEE 802.11b
 - Sin WEP:
 - SSID y MACs pueden ser escuchados en el aire (wireless sniffer)
 - Las MAC pueden ser configuradas en forma manual en los adaptadores
 - WEP:
 - Es vulnerable a ataques de fuerza bruta
 - Antes de realizar las escuchas se requiere un paso previo para vulnerar el algoritmo.
 - Con tecnología disponible y software de dominio público se demora minutos en vulnerar el algoritmo.



Seguridad en WLAN

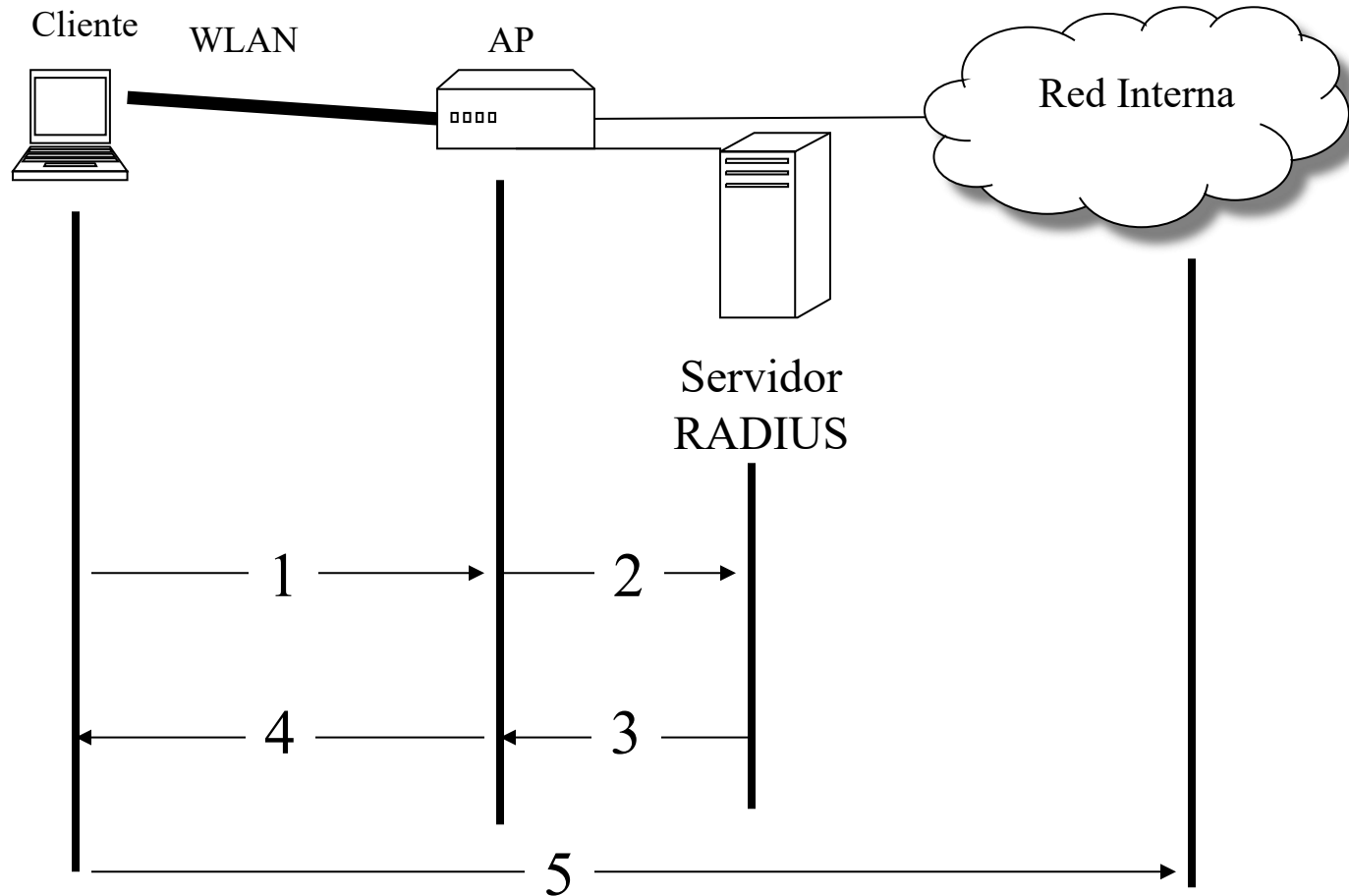
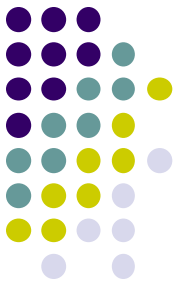
- 802.11x
 - Autenticación (EAP)
- WPA (Wifi Protected Access)
- 802.11i
 - Sustituye WEP por AES
- VPN (Virtual Private Network)



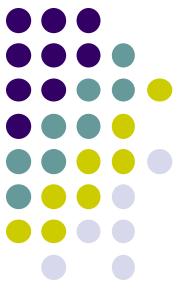
802.1x/EAP

- 802.1x es un protocolo de control de acceso y autenticación basado en la arquitectura cliente/servidor, que restringe la conexión de equipos no autorizados a una red.
- El protocolo 802.1x fue diseñado para emplear servidores RADIUS.
- El protocolo 802.1x involucra tres participantes
 - El cliente , que desea conectarse con la red.
 - El servidor de acceso o autenticador, que gestiona el permiso para acceder y otorga o deniega el acceso.
 - El servidor de autenticación quién decide si el cliente puede o no acceder a la red.
- El protocolo de autenticación del cliente se denomina EAP (Extensible Authentication Protocol)

Seguridad en WLAN – 802.1x



Ejemplo de configuración en la estación



HS propiedades [?] [X]

Asociación Autenticación Conexión

Nombre de red (SSID): HS

Clave de red inalámbrica

Esta red requiere una clave para lo siguiente:

Autenticación de red: WPA-PSK

Cifrado de datos: Abierta
Compartida
WPA

Clave de red: WPA-PSK

Confirme la clave de red:

Índice de clave (avanzado): 1

☐ La clave la proporciono yo automáticamente

☐ Ésta es una red de equipo a equipo (ad hoc). No se utilizan puntos de acceso inalámbrico

Aceptar Cancelar

HS propiedades [?] [X]

Asociación Autenticación Conexión

Seleccione esta opción para proporcionar acceso autenticado a redes Ethernet inalámbricas.

☒ Habilitar la autenticación IEEE 802.1X en esta red

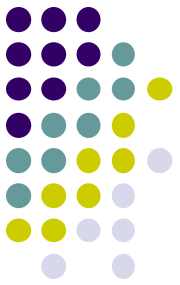
Tipo de EAP: Tarjeta inteligente u otro certificado
EAP protegido (PEAP)
Tarjeta inteligente u otro certificado

☒ Autenticar como equipo cuando la información de equipo esté disponible

☐ Autenticar como invitado cuando el usuario o la información de equipo no estén disponibles

Aceptar Cancelar

Ejemplo de configuración en el access point



WIRELESS NETWORK SETTINGS

Enable Wireless : ☒

Wireless Network Name : (Also called the SSID)

Enable Auto Channel Selection : ☐

Wireless Channel :

Transmission Rate : (Mbit/s)

WMM Enable : ☐ (Wireless QoS)

Enable Hidden Wireless : ☐ (Also called the SSID Broadcast)

WIRELESS SECURITY MODE

Security Mode :

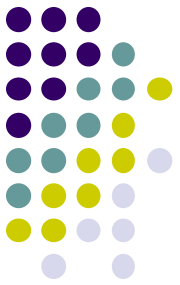
WPA / WPA2

WPA/WPA2 requires stations to use high

Cipher Type :

PSK / EAP :

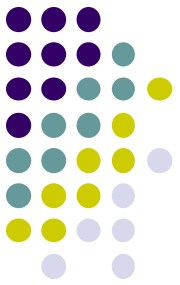
Network Key : (8~63 ASCII or 64 HEX)



WPA (WI-FI Protected Access)

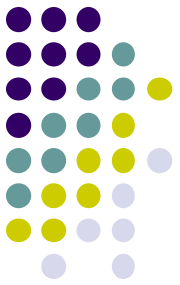
- Algoritmo de cifrado mejorado (TKIP)
 - Largo de claves de 128bits
 - Claves de sesión dinámicas
- Autenticación por 802.1x y EAP en dos modalidades:
 - Enterprise:
 - Requiere un servidor RADIUS en la red. El punto de acceso emplea entonces 802.1x y EAP para la autenticación, y el servidor RADIUS suministra las claves compartidas que se usarán para cifrar los datos.
 - Home o PSK (Pre-Shared Key):
 - La autenticación se establece a través de una contraseña compartida entre el punto de acceso y en los dispositivos móviles. Una vez logrado el acceso, TKIP entra en funcionamiento para garantizar la seguridad del acceso. Deben utilizarse contraseñas largas (20 o más caracteres) para no ser vulnerable a ataques.

WPA2 (WI-FI Protected Access)



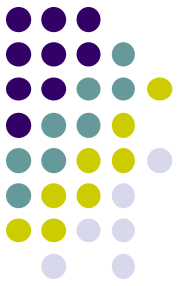
- WPA2 es la versión “estandarizada” de WPA, ya que WPA fue definido por la Wifi Alliance y WPA2 estandarizado por la IEEE en forma de la norma 802.11i.
- Se reemplaza el código de autenticación de mensajes
- Se reemplaza RC4 por AES como algoritmo de cifrado.

Ataques a WPA/WPA2



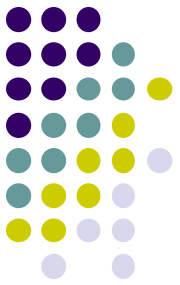
- El modo personal o PSK de los protocolos WPA y WPA2 son susceptibles a ataques de fuerza bruta y diccionario.
- Lo más importante es elegir escogemos una clave lo suficientemente robusta para dificultar ataques fuerza bruta.
- Si se requiere un alto nivel de seguridad se debe utilizar la modalidad “Enterprise” con un servidor de autenticación RADIUS.

WPS (Wifi Protected Setup)



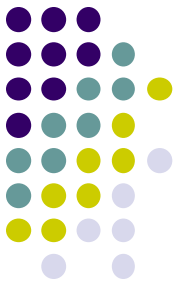
- WPS (Wi-Fi Protected Setup) es un estándar promovido por la Wifi Alliance para la creación de redes WLAN seguras sin necesidad de establecer complicados mecanismos de autenticación. Simplemente los dispositivos se enlazan entre sí con el conocimiento de un PIN, al estilo de las conexiones bluetooth.
- WPS define los mecanismos a través de los cuales los diferentes dispositivos de la red obtienen las credenciales (SSID y PSK) necesarias para iniciar el proceso de autenticación.
- WPS no es un protocolo de seguridad en sí, ya que se trata de la definición de diversos mecanismos para facilitar la configuración de una red WLAN segura con WPA2-PSK, pensados para minimizar la intervención del usuario en entornos domésticos o pequeñas oficinas.

Funcionamiento de WPS

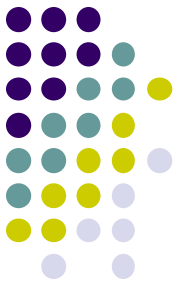


- WPS se implementa a través de los siguientes roles :
 - **Registrar**: dispositivo capaz de actuar como la autoridad para proporcionar el acceso y las credenciales a la red inalámbrica.
 - **Enrollee**: el dispositivo que solicita el acceso a la red inalámbrica y no posee configuración alguna.
 - **Authenticator**: normalmente es el propio AP (Access Point) que realiza la comunicación (Proxy) entre el Registrar y Enrollee.
- WPS contempla 4 formas de intercambio de credenciales y solicitud de autorización para acceso a la red inalámbrica:
 - **Método PIN**: introducir un PIN en el router y en el dispositivo.
 - **Método PBC**: Presionar un botón físico existente en el router que permite la conexión por un tiempo limitado.
 - **Método NFC** : Por proximidad entre el dispositivo y el Router.
 - **Método USB**: A través de la conexión a un puerto USB del AP

Vulnerabilidad en WPS



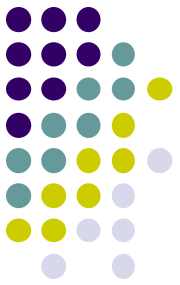
- El protocolo WPS posee una vulnerabilidad en el proceso de autenticación que permite a un atacante descubrir el PIN de acceso a la red que usa el AP en el protocolo WPS a través de un ataque de fuerza bruta.
- El ataque es posible, debido a que el protocolo WPS no limita el número de intentos posibles. Además la vulnerabilidad detectada reduce el tiempo necesario para realizar este tipo de ataque, a un intervalo de tiempo de horas.
- Por el momento, la solución más efectiva sería desactivar el protocolo WPS, ya que cualquier dispositivo certificado por la WiFi Alliance, contiene la vulnerabilidad explicada.



Segurización del TCP/IP

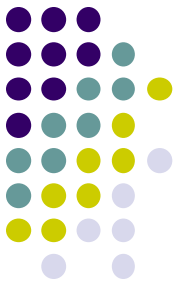
- NAT
- PAT - NATP
- Tunneling
- IPSEC
- IPv6

NAT - El problema del direccionamiento IP



- Espacio de direccionamiento IP en Internet limitado
- Obtener un bloque de direcciones registradas es difícil y costoso
- Se busca utilizar la cantidad mínima de direcciones IP.
- Se utilizan direcciones IP privadas en la red interna.
- Las direcciones IP privadas que se pueden utilizar para la red interna son:
 - Clase A: 10.x.x.x
 - Clase B rango: 172.16.x.x–172.31.x.x
 - Clase C rango: 192.168.1.x–192.168.254.x

NAT - Funcionamiento



- El router o dispositivo que realiza el NAT interconecta dos redes, una pública y una privada.
- A cada paquete que se envía desde la red privada a la red pública, se le cambia la dirección origen (IP privada) por una IP pública, y esta relación se almacena en una tabla.
- A su vez a cada paquete que ingresa a la red privada desde la red pública se le cambia la dirección destino por su correspondiente IP privada, que se obtiene de la tabla de NAT.

NAT

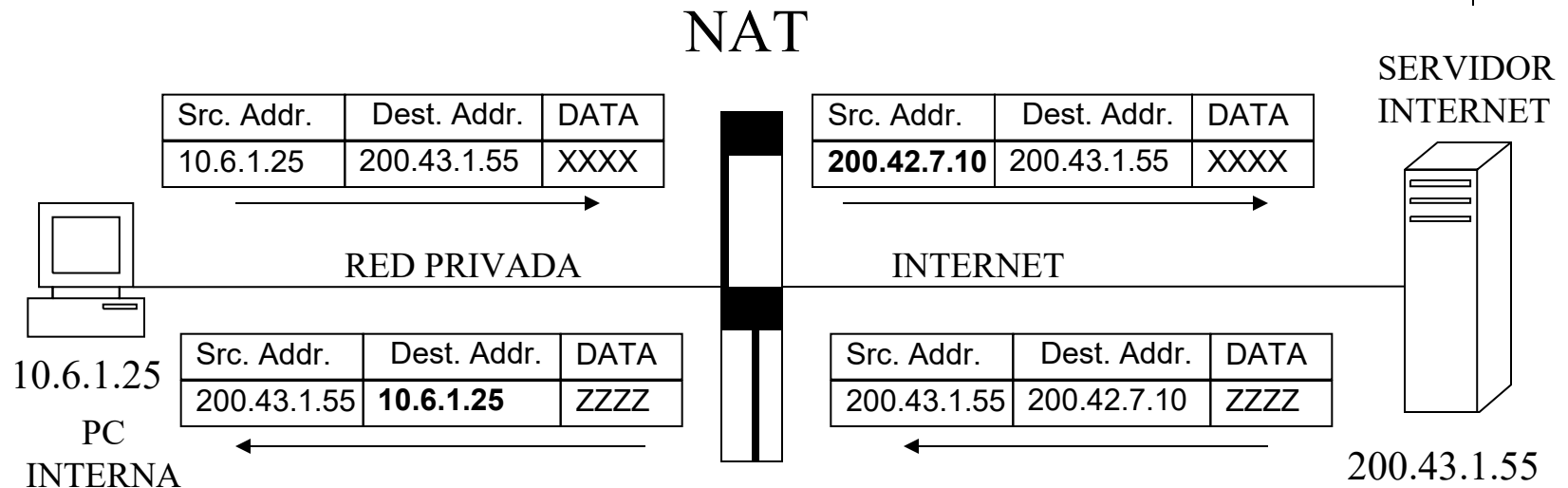
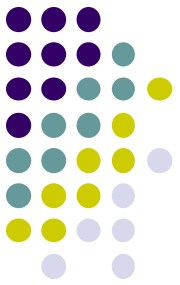
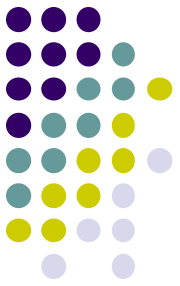


TABLA DE NAT	
Externa	Interna
200.42.7.10	10.6.1.25
200.42.7.11	-
....	-
200.42.7.20	-



Beneficios de NAT

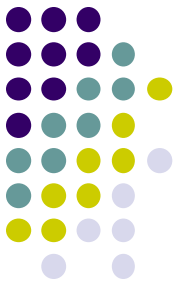
- Reemplaza la dirección origen con una dirección ruteable (válida en Internet) permitiendo a hosts con direcciones privadas acceder a Internet.
- Elimina la necesidad de reasignar números a los hosts al cambiar de ISP o de esquemas de direccionamiento.
- Fortalece la privacidad de la red puesto que las direcciones asignadas se encuentran ocultas.

Tipos de NAT



Las traducciones NAT pueden ser estáticas ó dinámicas

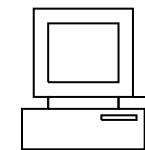
- Estáticas
 - Se utilizan cuando se desea que un host específico sea traducido a una IP específica.
 - Generalmente utilizado para servidores de Internet (www, ftp, etc.)
 - Se mantiene en una tabla fija la relación 1 a 1 entre la IP interna y la externa
- Dinámicas
 - Se utiliza cuando no se necesita tener siempre la misma dirección IP en Internet.
 - Cuando un computador de la red interna quiere acceder a Internet utiliza una dirección libre de la lista de asignación dinámica.
 - Genera un Firewall entre ambas redes, ya que un host de la red externa podrá enviar tráfico hacia la red interna únicamente cuando la conexión ha sido iniciada desde un computador interno.



PAT - NATP

- El funcionamiento de PAT (Port Address Translation) o NATP es similar al del NAT, con el agregado que la traslación incluye los puertos TCP o UDP además de las direcciones IP.
 - permitire traducción de varios a uno.
 - Mapea múltiples direcciones IP a una ó a unas cuantas.
 - Un número único de puerto origen identifica cada sesión.
 - Utiliza una o más direcciones IP que se asignan en forma dinámica

PAT



10.6.1.25
PC
INTERNA

Src. Addr.	Dest. Addr.
10.6.1.25	200.43.1.55
Src. Port	Dest. Port
1025/tcp	80/tcp
DATA	
XXXX	

RED PRIVADA

Src. Addr.	Dest. Addr.
200.43.1.55	10.6.1.25
Src. Port	Dest. Port
80/tcp	1025/tcp
DATA	
YYYY	



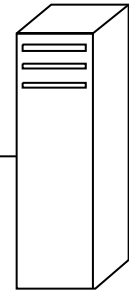
Src. Addr.	Dest. Addr.
200.42.7.1	200.43.1.55
Src. Port	Dest. Port
2050/tcp	80/tcp
DATA	
XXXX	

INTERNET

Src. Addr.	Dest. Addr.
200.43.1.55	200.42.7.1
Src. Port	Dest. Port
80/tcp	2050/tcp
DATA	
YYYY	

200.42.7.1

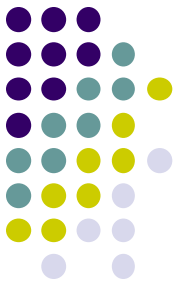
SERVIDOR
INTERNET



200.43.1.55
www
en port 80/tcp



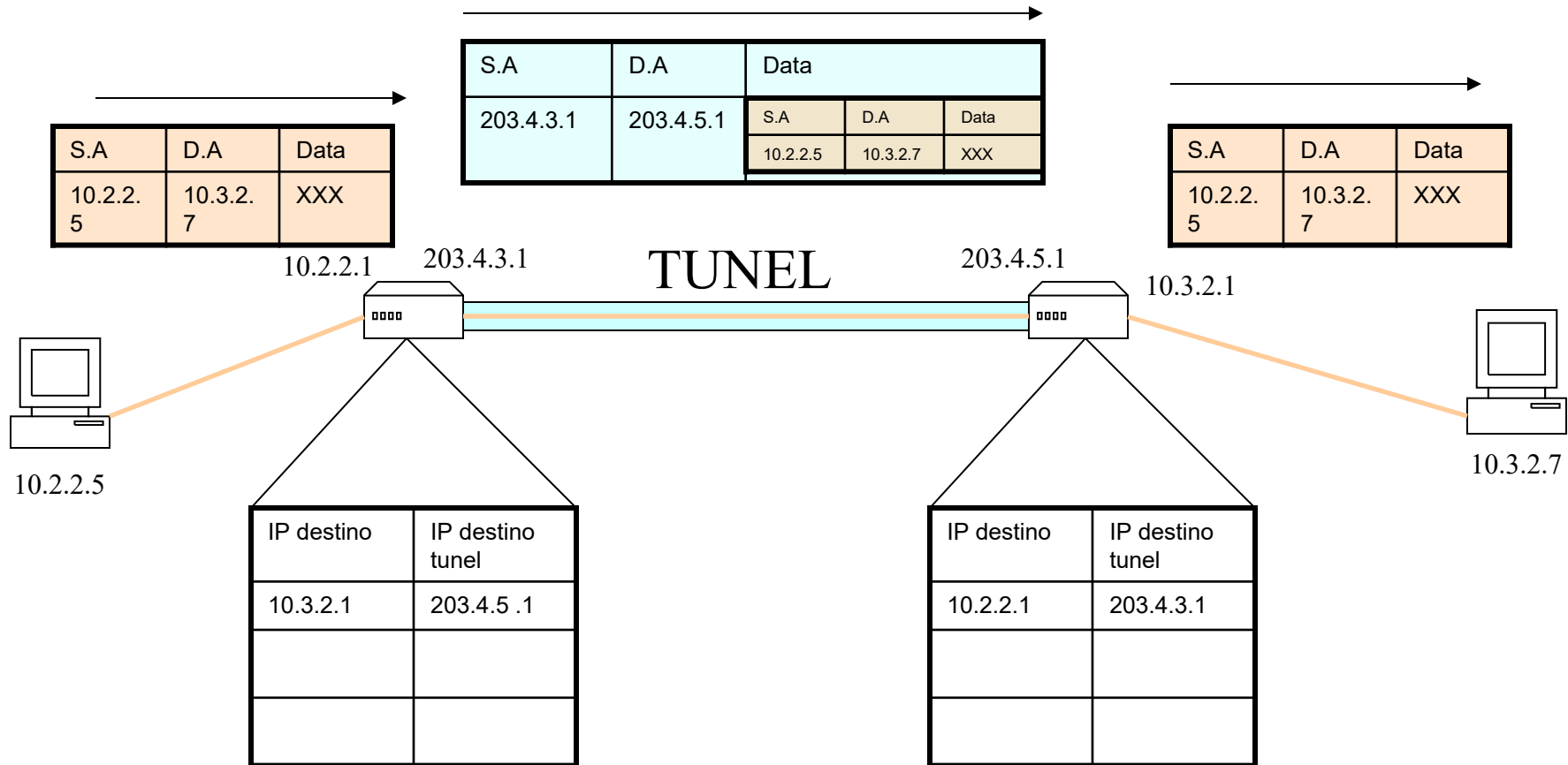
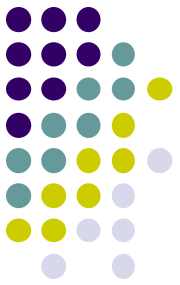
TABLA DE PAT – 200.42.7.1			
IP Interna	Port Interno	IP Externa	Port externo
10.6.1.25	1025	200.43.1.55	2050
10.6.1.25	1026	195.16.2.32	2051
10.6.1.26	1025	200.43.1.55	2052



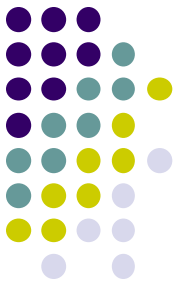
Tunneling – Definción

- Se denomina “Tunneling” a la transmisión de paquetes de datos de un determinado protocolo encapsulados en otro, de manera que el contenido del paquete original puede llegar inalterado a su destino, creando algo así como una conexión punto a punto virtual a través de una red

Tunelling – Ejemplo



IPSec



- IPSec es una extensión al protocolo IP que proporciona seguridad a IP y a los protocolos de capas superiores.
- Fue desarrollado para el nuevo estándar IPv6 y después fue portado a IPv4.
- Puede proteger el datagrama IP completo (modo túnel) o sólo los protocolos de capas superiores (modo transporte)
- En modo túnel el datagrama IP se encapsula completamente dentro de un nuevo datagrama IP que emplea el protocolo IPSec.
- En modo transporte IPSec sólo maneja la carga del datagrama IP, insertándose la cabecera IPSec entre la cabecera IP y la cabecera del protocolo de capas superiores.

IP v6 – Modo túnel y modo transporte

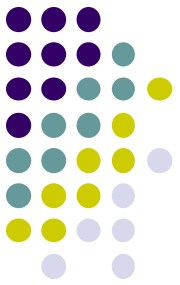


Figura 6a. Modo transporte

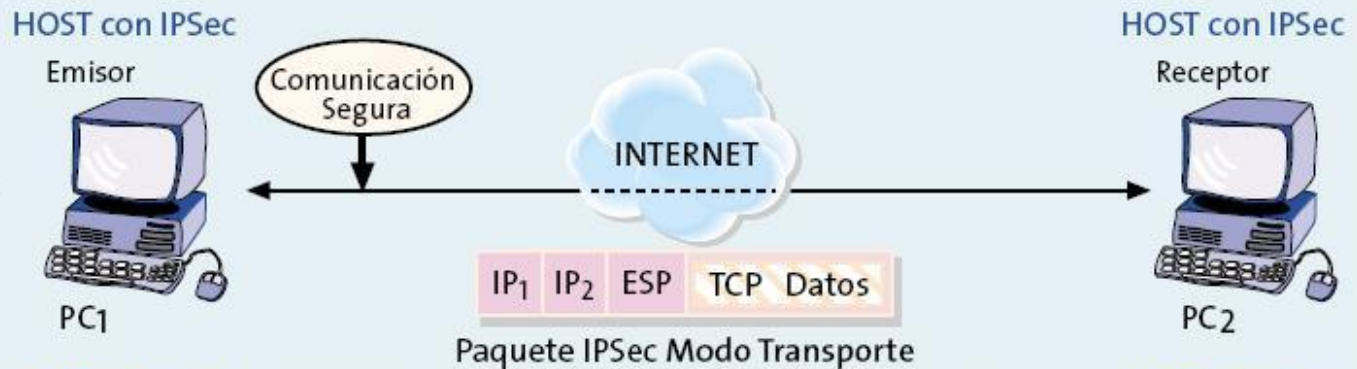
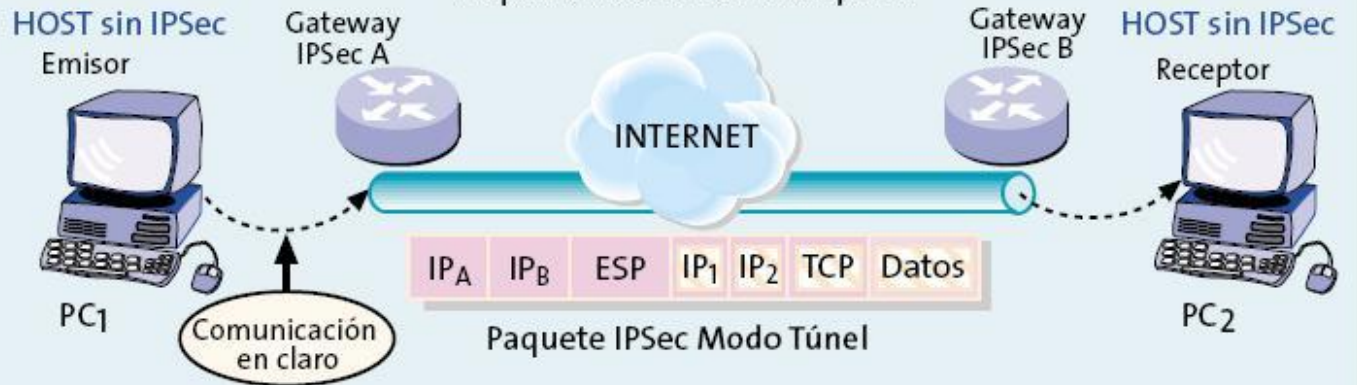
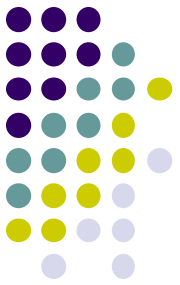


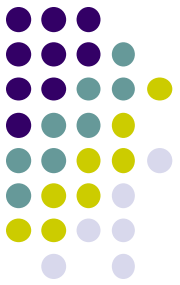
Figura 6b. Modo túnel





IPSec - Protocolos

IPsec emplea dos protocolos diferentes, AH y ESP, para asegurar la autenticación, integridad y confidencialidad de la comunicación y un protocolo adicional llamado IKE para implementar el intercambio seguro de claves.

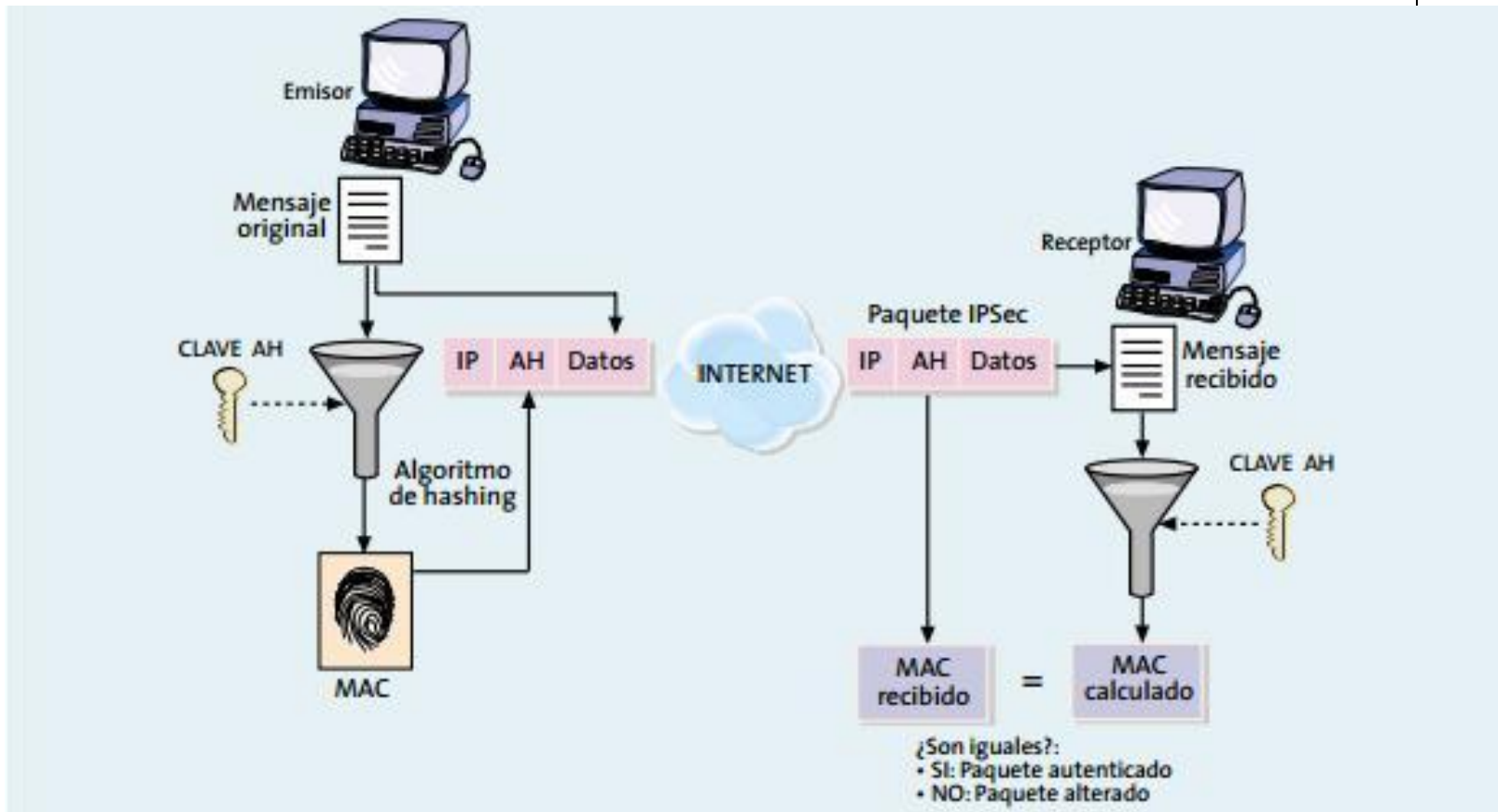
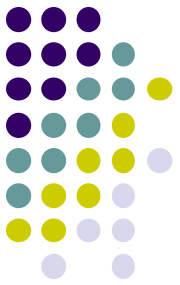


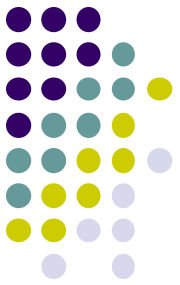
IPSec - Protocolos

AH – (Authentication Header)

- El protocolo AH protege la integridad del datagrama IP. Para ello emplean códigos de autenticación de mensaje (HMAC - Hash Message Authentication Codes) usando algoritmos como MD5 y SHA.
- Toma como base para el cálculo la clave secreta, el contenido del paquete y partes inalterables de la cabecera IP (como son las direcciones IP). Luego añade la cabecera AH al paquete y envía el mismo al receptor, quién verifica la información recalculando el HMAC.

IP v6 - AH (Authentication Header)

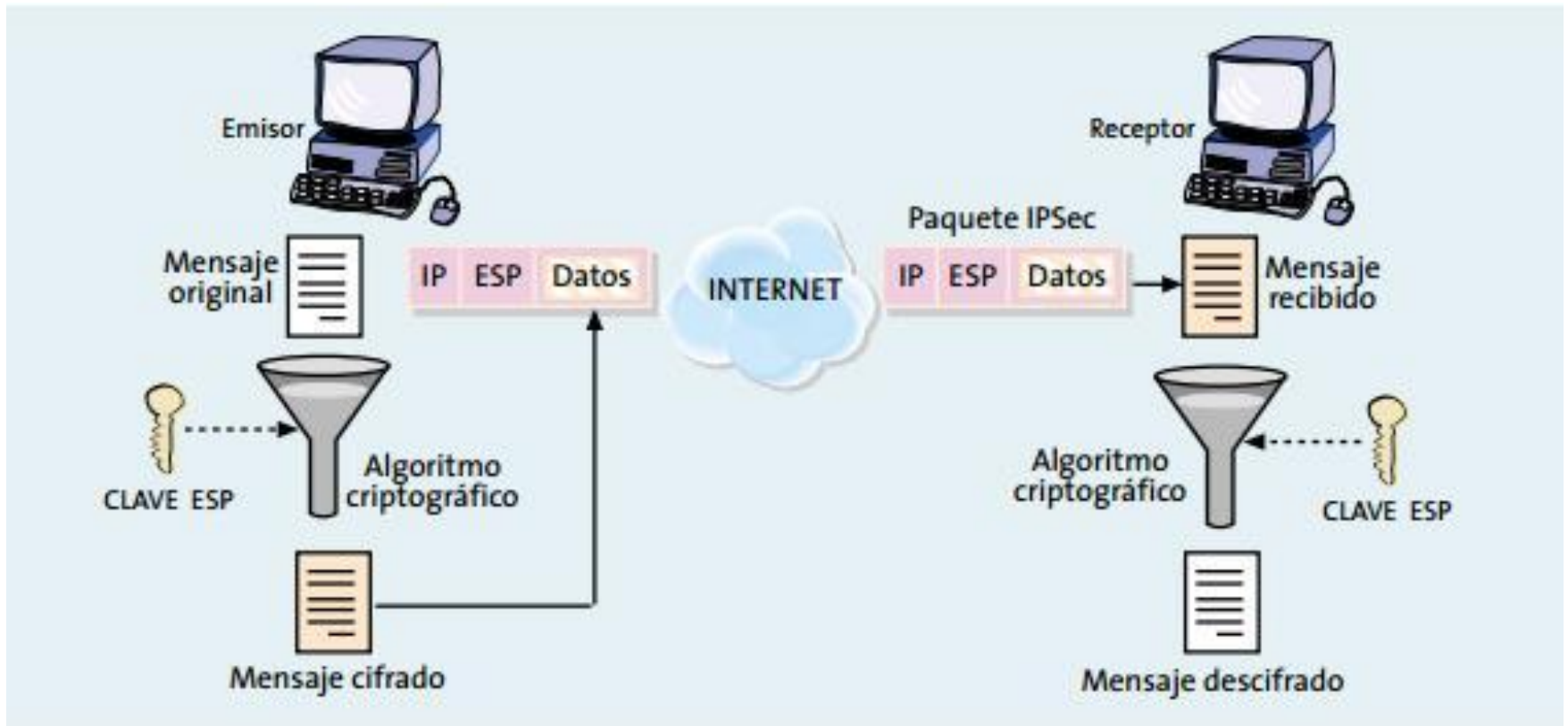
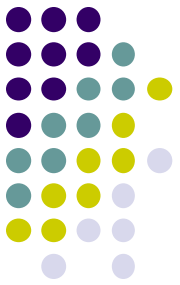


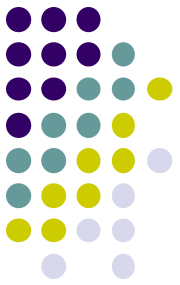


IPSec - Protocolos

- **ESP (Encapsulated Security Payload)**
- El protocolo ESP puede asegurar la integridad del paquete empleando HMAC y la confidencialidad empleando cifrado. Para ello se utilizan algoritmos estándar de cifrado simétrico como por ej. 3DES, AES y Blowfish.
- La cabecera ESP se genera y añade al paquete tras cifrarlo y calcular su HMAC.

IP v6 - ESP (Encapsulated Security Payload)

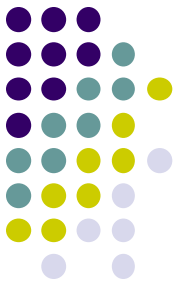


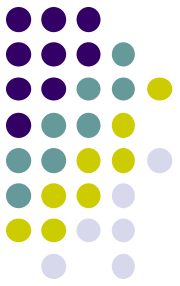


IPSec - Protocolos

- **Protocolo IKE (IKE - Internet Key Exchange Protocol)**
- El protocolo IKE Resuelve el problema de intercambio de claves por Internet.
- Primero autentica a los participantes y luego negocia los parámetros de seguridad y escoge las claves secretas simétricas, intercambia las mismas a través de un canal seguro establecido previamente a través del intercambio de claves públicas y luego se ocupa de renovar periódicamente las claves para asegurar su confidencialidad.

IPSec - IKE (Internet Key Exchange Protocol)



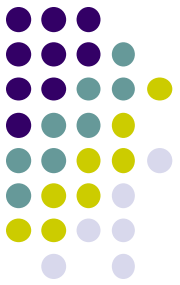


VPN

VPN



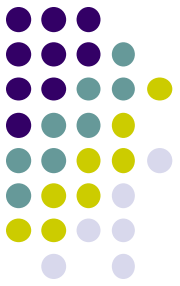
- VPN (Virtual Private Network) es una extensión de una red local y privada que utiliza como medio de enlace una red publica como por ejemplo, Internet.
- Este método permitire enlazar dos o mas redes simulando una única red privada permitiriendo así la comunicación entre computadoras como si fuera punto a punto.
- También permitire que un usuario remoto se puede conectar individualmente a una LAN utilizando una conexión VPN, y de esta manera utilizar aplicaciones, enviar datos, etc. de manera segura.



VENTAJAS DE UNA VPN

- Seguridad: provee encriptación y encapsulación de datos de manera que hace que estos viajen codificados y a través de un túnel.
- Costos: ahorran grandes sumas de dinero en líneas dedicadas o enlaces físicos.
- Mejor administración: cada usuario que se conecta puede tener un numero de IP fijo asignado por el administrador, lo que facilita algunas tareas como por ejemplo mandar impresiones remotamente, aunque también es posible asignar las direcciones IP dinámicamente si así se requiere.
- Facilidad para los usuarios con poca experiencia para conectarse a grandes redes corporativas transfiriendo sus datos de forma segura.

VPN - Tecnología



Las VPNs se basan en las siguientes tecnologías

- Firewalls: Como mecanismo de protección adicional
- Autenticación : Para dar acceso sólo a sistemas permitidos
- Encriptación : Para asegurar confidencialidad e integridad
- Tunneling: Como mecanismo de intercambio de información

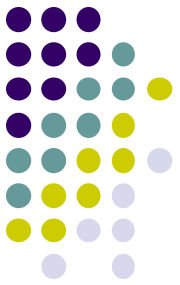
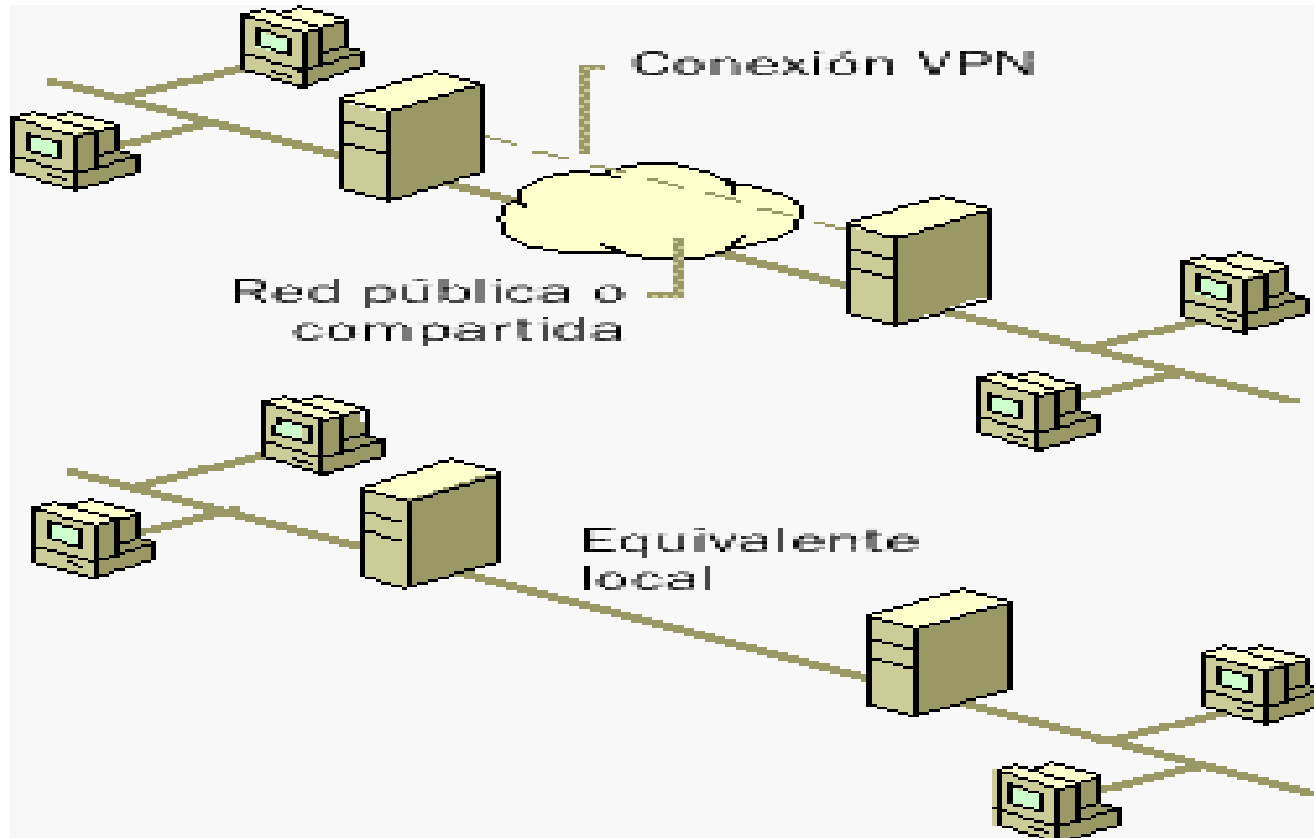
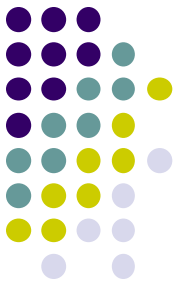


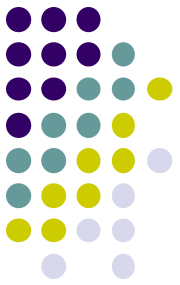
Diagrama lógico de una VPN





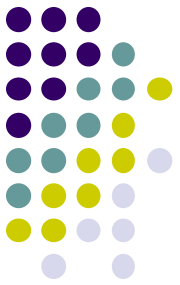
Servicios de una VPN

- Encapsular los datos
- Autenticar usuarios.
- Encriptar los datos
- Aplicar filtros de acceso a las conexiones (ACL)
- Asignar direcciones IP de manera estática y/o dinámica



ELEMENTOS DE UNA VPN

- Para el correcto armado de una VPN, es necesario cumplir con una serie de elementos y conceptos que a continuación se detallan:
 - ***Conexión a red pública o Internet:***
 - ya sea por conexión IP dedicada, ADSL o incluso dial-up.
 - **Servidor VPN:**
 - Computador conectado a Internet esperando por conexiones de usuarios VPN y si estos cumplen con el proceso de autenticación, el servidor aceptará la conexión y dará acceso a los recursos de la red interna.
 - **Cliente VPN:**
 - Este puede ser un usuario remoto o un computador o enrutador de otra LAN, según el tipo de conexión.



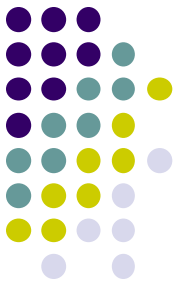
Tipos de VPN

- Hay distintas posibilidades de conexiones VPN, según se quiera enlazar dos o mas redes, o si solo se conectaran usuarios remotos.

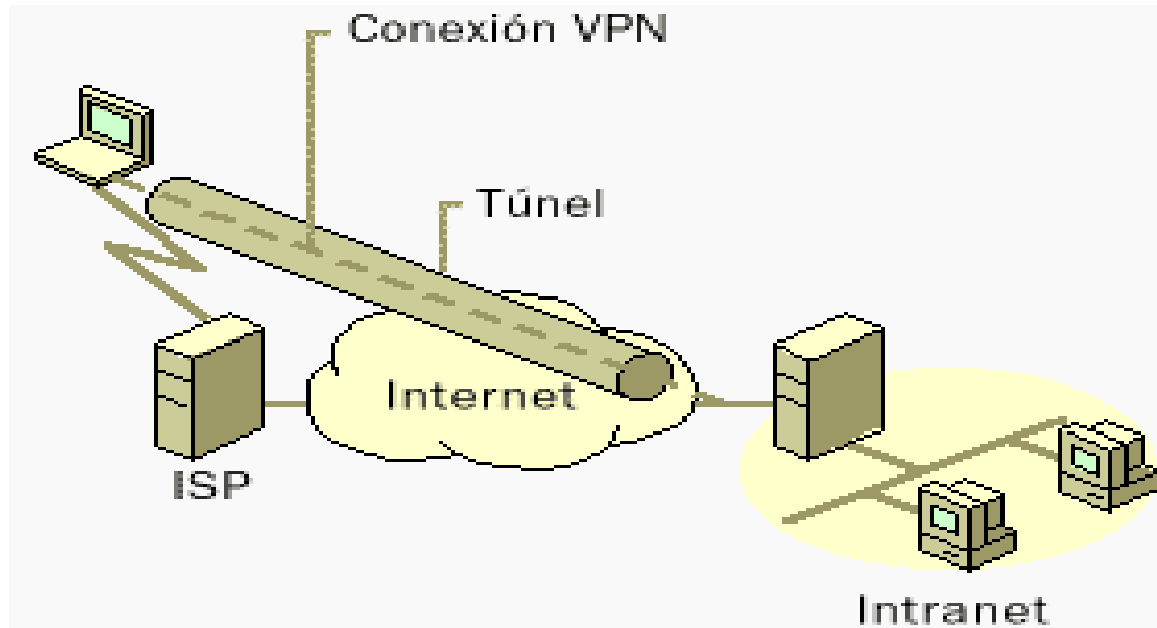
Las posibilidades son:

- VPN Cliente
- VPN Site-to-Site

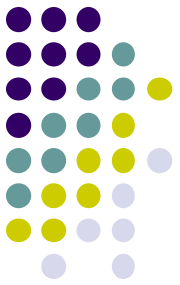
DE CLIENTE A RED INTERNA (VPN Cliente)



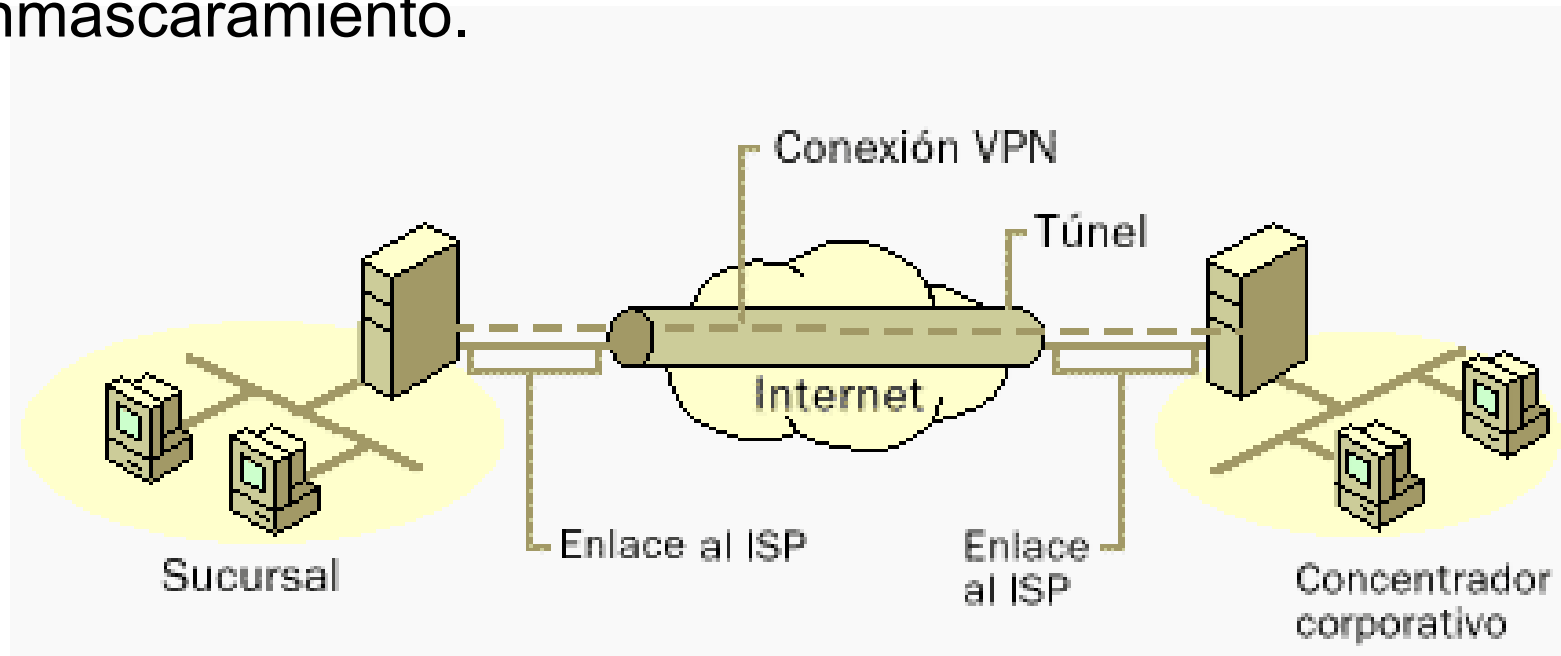
- Un usuario remoto que utilizara servicios o aplicaciones que se encuentran en uno o mas equipos dentro de la red interna.

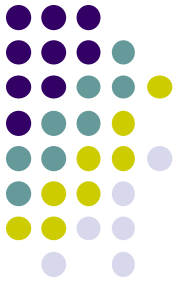


VPN Site-to-Site (LAN to LAN)

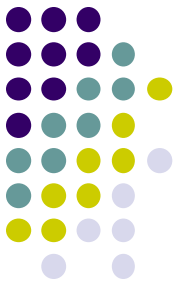


Une 2 intranets a través de 2 enrutadores: el servidor VPN en una de las intranets y el cliente VPN en la otra. Aquí entran en juego el mantenimiento de tablas de ruteo y enmascaramiento.





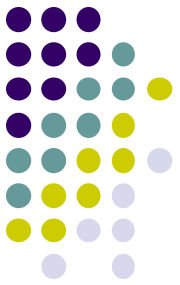
IPv6



Qué es IPv6 ?

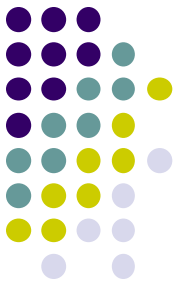
- El Internet Protocol version 6 (IPv6) es una nueva versión del protocolo IP, diseñada para reemplazar a Internet Protocol version 4 (IPv4), que actualmente está implementado en la gran mayoría de dispositivos que acceden a Internet.
- Su implementación en Internet es impulsada principalmente debido a que el crecimiento en los últimos años de los dispositivos conectados a Internet está provocando el agotamiento de las direcciones disponibles en el protocolo actual IPv4.

Ver Documento anexo : **¿Qué pasaría si Internet se quedara sin espacio?**



Ventajas de IPv6

- La principal ventaja de IPv6 con respecto a su antecesor IPv4, es que se amplía el espacio de direcciones a 340 sextillones (10^{36}) direcciones posibles.
- Con este esquema de direccionamiento tan grande, IPv6 tiene la capacidad de proporcionar direcciones únicas para todos y cada dispositivo o nodo conectado a Internet y por lo tanto se elimina la necesidad de utilizar técnicas como la traducción de direcciones de red (NAT) para evitar quedarse sin espacio de direcciones disponible.



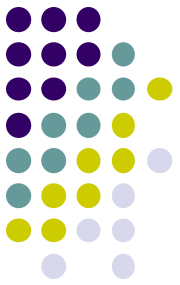
Ventajas de IPv6

- **Calidad de Servicio (QoS)**

- Ayuda a aliviar la congestión en las redes de conmutación de paquetes, dividiendo el tráfico en diferentes clases en momentos de congestión, y gestionando con prioridad de servicio a aquellas comunicaciones más sensibles a demoras.

- **Movilidad**

- Con el IPv6, el acceso móvil de Internet se simplifica en gran medida, ya que incorpora un protocolo específico, llamado IP móvil para soportar la movilidad. En un entorno IPv6, no hay soporte para roaming entre redes diferentes.



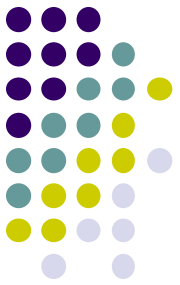
Ventajas de IPv6

- **Multidifusión**

- Se denomina multidifusión (o multicast) a la capacidad de un dispositivo de enviar información simultánea a múltiples receptores.
- El soporte de multidifusión se incluye de manera estándar dentro del protocolo IPv6, por lo que las comunicaciones multicast se realizan de manera más rápida, sencillo y confiable.

- **Seguridad**

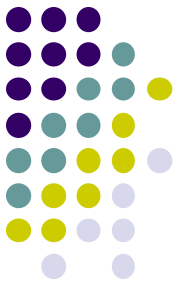
- IPv6 incorpora el protocolo de seguridad de Internet (IPsec) en forma nativa, que proporciona la autenticación, el cifrado y la compresión del tráfico IP, aunque cabe aclarar que su implementación es opcional.



Direccionamiento IPv6

- Las direcciones IPv4 de 32 bits se escriben normalmente como 4 octetos (conjunto de 8 bits) escritos en decimal y separados por puntos. Ej: 192.168.170.1
- Las direcciones IPv6, al ser de 128 bit de longitud, se representan normalmente en 8 secciones de 16 bit separadas por dos puntos y convertidas a 4 dígitos hexadecimales.
- Ej : 2025:0cd8:435a:0301:0000:0000:1b2e:2c4c
- Estas direcciones son muy largas por lo que se pueden resumir quitando ceros. La dirección del ejemplo se puede resumir de esta manera:

2025:0cd8:435a:0301::1b2e:2c4c



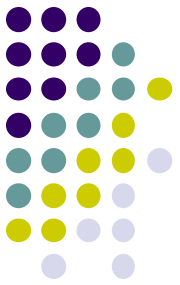
Direccionamiento IPv6

- **Partes de la dirección IPv6**

En una dirección las ocho secciones de 16 bit se pueden agrupar de la siguiente manera (las x representan los números hexadecimales de la dirección):

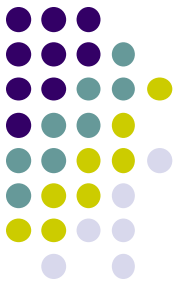
prefijo del sitio	- id de subred	- id del interfaz
48 bit	16 bit	64 bit
x:x:x	:x:	x:x:x:x

Típicamente el prefijo del sitio lo asignará nuestro ISP pero en cambio el id de subred lo asignaremos nosotros para nuestro sitio. Finalmente, el id del interfaz se configura automáticamente a partir de la MAC de la tarjeta de red del equipo o manualmente

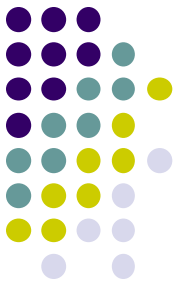


Direccionamiento IPv6

- **Tipos de direcciones IPv6**
- **Unicast:** los paquetes se envían a una única interfaz.
- **Multicast:** se utilizan para comunicar desde una fuente a muchas interfaces destino miembros de un determinado grupo de multicast.
- **Anycast:** las direcciones anycast identifican un grupo de interfaces en nodos diferentes. Cuando se envía un paquete a una dirección anycast sólo el miembro del grupo que esté físicamente más cerca del remitente recibe el paquete.



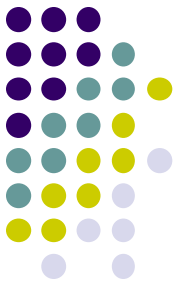
Sistemas Activos de Protección



Sistemas de Detección de Intrusos

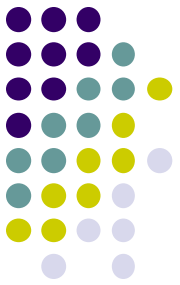
- Es un sistema formado por un conjunto de sensores localizados estratégicamente en la red interna para detectar ataques
- El análisis se realiza en base a la detección de patrones de ataques conocidos (Firmas), o de comportamiento anormal.

Sistemas de Detección de Intrusos



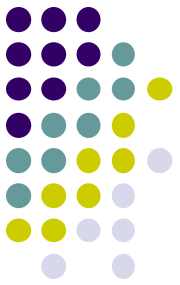
- Sistema de Detección de Intrusiones (IDS)
 - No interfieren con el tráfico
 - Generalmente se instalan para que analicen el tráfico :
 - Desde redes externas a la red interna
 - Desde la red interna al exterior
 - Desde las estaciones de la red interna a redes de servidores o equipos críticos.

Sistemas de Detección de Intrusos



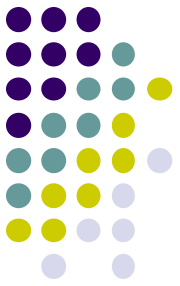
- Firmas (Signatures)
 - Las firmas son patrones en el tráfico que indican la presencia de un intento de ataque o situación anormal.
 - Cuando se detecta un patrón se genera una alerta y se registra el evento en una base de datos
 - Los fabricantes de NIDS publican regularmente nuevas firmas (actualización similar a la de los antivirus)
 - Ejemplos de patrones :
 - Port scanning: Intentos de acceso a puertos en forma consecutiva a una misma IP
 - Paquetes con dirección IP origen y destino iguales o nulos
 - URLs con vulnerabilidades conocidas (por ej, SQL Injection).

Sistemas de Prevención de Intrusos (IPS)



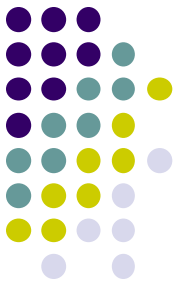
- Los IPS utilizan las mismas tecnologías de detección que los IDS, pero además tienen la capacidad de prevenir ataques a través del filtrado del tráfico malicioso.
- Para ello todo el tráfico entrante y saliente desde la red que se quiere controlar (generalmente internet) debe pasar por el IPS.
- Pueden integrar otras funcionalidades de seguridad como firewall de aplicación, antivirus, control de SPAM, VPN, etc.
- Deben tener un alto poder de procesamiento para no degradar el tráfico de red
- Son muy útiles para proteger de un ataque de “Día Cero” a través de análisis de comportamiento.

HoneyPots



- Son sistemas ficticios que emulan un servidor no protegido y se utilizan para poder observar la actividad de los intrusos.
- Tienen como objetivo distraer y disuadir a los intrusos para que no ataquen los sitios reales
- Mediante el análisis de logs se detectan las direcciones IP de los atacantes y la metodología utilizada y esta información se utiliza para prevenir intrusiones de los sitios operativos.

Sandboxing



- Es una tecnología que permite ejecutar aplicaciones y programas con seguridad y aislarlas del resto del sistema dentro de una especie de contenedor o máquina virtual desde el cual se puede controlar los distintos recursos que solicita dicha aplicación (memoria, espacio en disco, privilegios necesarios, etc).
- Este mecanismo se utiliza, entre otras cosas, para discernir si el código a ejecutar es malicioso o no, lo que por un lado protege a los usuarios al detectar el malware en forma temprana y por otro permite estudiar el comportamiento de un malware dentro de un entorno controlado y ver qué efectos tiene en un sistema para proceder a su caracterización y posterior mitigación.

Sandboxing

